

Evidential Conformal Guardrails (ECG): Mathematically Guaranteed Defenses Against Zero-Day Prompt Injections

Document Purpose: Formal Justification of Research Novelty for IEEE Q1 Submission

1. The Research Gap (Flaws in Current State-of-the-Art)

Across over 60 recent papers (2023-2025) on LLM security, the literature assumes a binary classification paradigm: a prompt is either SAFE or BLOCKED. However, current fast-inference frameworks lack **Mathematical Humility**. Top-tier journals (IEEE S&P, USENIX, IEEE TIFS) are actively rejecting papers that propose "just another classifier." They demand theoretical guarantees and explicit uncertainty quantification.

The most critical flaw in Generation 3 defenses (e.g., Meta's PromptGuard, BERT-based classifiers) is **Softmax Overconfidence**. When faced with a Zero-Day attack (a highly obfuscated prompt structure the model has never seen, such as a novel Hexadecimal+Leetspeak hybrid), standard Neural Networks are mathematically forced by the Softmax function to assign a high probability to a random class. They confidently misclassify novel attacks as "Clean", causing silent security failures.

2. How ECG Wins by Novelty (Level 5 Methodological Breakthrough)

We introduce Evidential Conformal Guardrails (ECG), which fundamentally breaks away from standard classifiers by attacking the Softmax Overconfidence problem directly. Our system wins through three defensible, mathematically rigorous novelties:

Novelty 1: Evidential Deep Learning (EDL) for Out-of-Distribution Detection

We replace the standard Softmax head with a Dirichlet distribution. The model mathematically derives its Epistemic Uncertainty, explicitly flagging Zero-Day attacks as "Unknown" rather than forcing a "Clean" classification.

Novelty 2: Evidential-Entropy Divergence (EED) Non-Conformity Scoring

Standard Conformal Prediction utilizes heuristic logit margins for non-conformity scoring, which fail silently against adversarial obfuscations (e.g., Base64, Leetspeak). We propose a fundamental methodological shift: Evidential-Entropy Divergence (EED). Rather than treating linguistic entropy as a flat penalty—which heavily penalizes legitimate developer queries containing code or hashes—EED mathematically couples the input-space Shannon Entropy with the latent-space Dirichlet Evidence.

We formulate the conformal non-conformity score as the quotient of lexical entropy and epistemic evidence. Consequently, benign high-entropy inputs (where the model exhibits high evidence) mathematically suppress the score, preventing False Positives on complex legitimate tasks. Conversely, adversarial Zero-Day geometries trigger an evidence collapse; the unsuppressed entropy forces the EED score to asymptotically spike, guaranteeing a Conformal Abstention. This yields the first conformal scoring function capable of mathematically disentangling adversarial obfuscation from legitimate linguistic complexity.

Novelty 3: Split Conformal Prediction for Distribution-Free Security

We calibrate the EED threshold on a hold-out set, guaranteeing that the true safety class is contained in the prediction set with a user-defined probability (e.g., 95%). This provides a hard statistical guarantee on the False Positive Rate, transforming the guardrail from a heuristic filter into a mathematically bounded risk engine.

3. Synthesis of Existing Literature (Taxonomy of Defenses)

Generation 1: Heuristic, Regex, and Lexical Filters

Representative Works: NeMo Guardrails (early versions), traditional WAFs.

Flaw: Brittle to obfuscation. Attackers bypass these using Base64, Zero-Width characters, or Leetspeak.

Generation 2: LLM-as-a-Judge & Semantic Filtering

Representative Works: Llama-Guard 1/2/3, ShieldGemma, Rebuff.

Flaw: Extreme latency (adds 1000ms+ per request) and susceptible to recursive prompt injection (the Judge LLM itself gets injected).

Generation 3: Standard Deep Learning & Embedding Classifiers

Representative Works: PromptGuard (Meta), RoBERTa injection classifiers.

Flaw: Softmax Overconfidence on Out-of-Distribution (OOD) data.

Generation 4: Randomized Smoothing & Perturbation

Representative Works: SmoothLLM, RAIN, Erase-and-Check.

Flaw: Astronomically high compute overhead requiring multiple LLM inference passes per prompt.

4. Paper Contributions Summary

- If challenged by a reviewer on why this is fundamentally novel, the rebuttal is straightforward:
- Unlike standard Evidential Conformal Prediction in Computer Vision, ECG introduces a domain-specific EED score that leverages linguistic entropy to catch adversarial text geometries that would otherwise bypass standard logit margins.

- By using a quotient-based divergence formulation, EED mathematically protects "Benign High-Entropy" developer queries (like raw Base64 or minified JSON) from false positives.
- It mathematically prevents "silent failures" on Zero-Day attacks by bounding the error rate.